

Mapeo detallado de preguntas a requisitos normativos y GQM

Encuesta AMPARO-ENS con enfoque GQM

Este mapeo complementa el anterior, incorporando la relación explícita entre Objetivos GQM, Preguntas de la encuesta y referencias ENS / CCN-STIC. [web:30][web:32][web:33][web:21][web:39]

Código pregunta	Objetivo GQM	Pregunta (resumen)	Métrica principal asociada	Referencias normativas ENS / CCN-STIC
1.1.1	G1	¿Existe una política de seguridad aprobada por el órgano de dirección?	M1.0 – Existencia y vigencia de política	ENS art. 11; Anexo II (organización de la seguridad). [web:30]
1.1.3	G1	¿Dispone la organización de un Comité de Seguridad de la Información?	M1.0b – Existencia y actividad del Comité	ENS Anexo II (gobernanza). [web:30]
1.2.1	G1/G6	¿Se cumplimenta el Informe INES de forma sistemática?	M6.0 – Uso efectivo de INES	ENS art. 12; CCN-STIC-824; plataforma INES. [web:30][web:21][web:33]
1.2.2	G1/G6	¿Se utiliza AMPARO para gobernanza ENS?	M6.0b – Uso de AMPARO en planes ENS	Herramientas CCN de gobernanza ENS. [web:21][web:39]
1.2.3	G1	¿Existe y se mantiene la Declaración de Aplicabilidad (DA)?	M1.2 – Edad de la DA; M1.2b – Cobertura DA	ENS Anexo II; CCN-STIC-808/88 1. [web:28][web:23]
1.3.1	G1	Porcentaje estimado de medidas ENS implantadas	M1.1 – % medidas ENS implantadas	ENS Anexo II; CCN-STIC-815 (métricas de cumplimiento). [web:32][web:35]
1.3.3	G1	Identificación y categorización de sistemas ENS	M1.3b – % sistemas categorizados	ENS art. 10, Anexo I. [web:30]
2.1.1	G2	Metodología de análisis de riesgos	M2.1 – Nivel de formalización	ENS art. 35; MAGERIT/PILAR; CCN-STIC sobre riesgos. [web:30][web:38]
2.1.2	G2	Frecuencia del análisis de riesgos	M2.2 – Antigüedad media de análisis	ENS art. 35; CCN-STIC-815 (periodicidad). [web:32]

2.1.3	G2	Registro consolidado de riesgos con planes de tratamiento	M2.3 – % de riesgos críticos gestionados	ENS art. 35; integración con gestión de riesgos. [web:30][web:38]
2.2.2	G3	Cobertura de MFA en accesos críticos	M3.1 – % cuentas privilegiadas/usuarios con MFA	ENS Anexo II (acceso); Zero Trust fabricantes. [web:2][web:11][web:15]
2.2.3	G3	Segmentación y microsegmentación de red	M3.2 – Índice de segmentación	ENS Anexo II (protección de redes). [web:30]
2.2.4	G3	Verificación contextual de accesos	M3.3 – % recursos con acceso condicional	Zero Trust (context-based access). [web:11][web:15]
2.3.1	G2	Cifrado de datos en tránsito	M2.4 – % servicios críticos con TLS seguro	ENS Anexo II (protección de la información). [web:30]
2.3.2	G2	Cifrado de datos en reposo	M2.5 – % bases de datos/almacenamientos cifrados	ENS Anexo II (protección de la información). [web:30]
2.3.3	G2	Análisis sobre riesgo criptográfico avanzado / post-cuántico	M2.6 – Existencia de análisis criptográfico	ENS art. 35; riesgo emergente. [web:12][web:3]
3.1.1	G4	Procedimiento formal de gestión de incidentes	M4.0 – Existencia y uso del procedimiento	ENS Anexo II (incidentes); CCN-STIC-817. [web:25]
3.1.3	G4	Cálculo de MTDD y MTTR	M4.1 – MTDD; M4.1b – MTTR	CCN-STIC-815 (eficacia); 817. [web:32][web:25]
3.2.1	G4	Cobertura de monitorización (SIEM/SOC)	M4.2 – % sistemas críticos monitorizados	ENS Anexo II (monitorización); CCN-STIC-815. [web:32][web:30]
3.3.1	G4	BCP/DRP que incluyan ciberincidentes	M4.3 – Existencia y grado de prueba	ENS Anexo II (continuidad); art. 27. [web:30]
3.3.3	G4	Medición y cumplimiento de RTO/RPO	M4.4 – % incidentes que cumplen RTO/RPO	ENS continuidad de servicios esenciales. [web:30]

4.1.1	G5	% del presupuesto TI dedicado a ciberseguridad	M5.1 – % presupuesto seguridad	CCN-STIC-815 (métricas de recursos); informes industriales. [web:32][web:8][web:13]
4.2.1	G5	Programas de formación en ciberseguridad	M5.2 – Cobertura de formación	ENS Anexo II (concienciación). [web:30]
4.2.2	G5	Campañas de concienciación (phishing, etc.)	M5.3 – Frecuencia y alcance de campañas	CCN-STIC-815 (métricas de cultura); informes sectoriales. [web:32][web:8][web:13]
5.1.1	G6	Existencia de cuadro de mando de ciberseguridad	M6.1 – Nº de indicadores activos	CCN-STIC-815/824 (sistema de métricas). [web:32][web:33]
5.1.3	G6	Uso de CCN-STIC-815/824 como referencia	M6.2 – Nivel de alineamiento	CCN-STIC-815/824 . [web:32][web:33]
5.2.1	G5/G6	Uso de INES/AMPARO para priorizar inversiones	M6.3 – Grado de integración métrica-planificación	ENS art. 12; INES/AMPARO. [web:21][web:39]
5.2.2	G5	Definición de modelos de ROI en ciberseguridad	M5.4 – Existencia de modelos ROI	CCN-STIC-815 (eficiencia/coste). [web:32]

Este cuadro puede extenderse incorporando columnas adicionales: pesos para el IGM, criterios PRAGMATIC clave y notas específicas por organización.